JC-STAR★1適合基準に対する第三者が利用可能な情報に基づく検証可能性に関する実証的調査

渡部 湊斗[1,a)]　眞田 颯哉[1]　上園 大智[1]　原 悟史[1,2]　村上 洸介[1,3]　藤井 翔太[1]　佐々木 貴之[1]
吉岡 克成[1]

概要：近年，IoT 機器を標的としたサイバー攻撃が深刻化する一方，ユーザが製品のセキュリティ対策を購入前に判断することは難しい．この課題を背景に，IoT 製品のセキュリティを共通基準で評価・可視化する JC-STAR が導入された．JC-STAR ★ 1 は，IoT 製品ベンダーの自己適合宣言に基づいて付与される．自己適合宣言を第三者が利用可能な情報からどこまで裏付けられるかを明らかにすることは，非公開証跡に基づく制度内部の確認とは異なる観点から，ラベルの透明性を高めることが期待される．そこで本研究では，★ 1 適合基準 16 項目について，評価ガイドが求める確認事項を第三者が利用可能な情報から検証できる範囲を整理した．その結果，6 項目は第三者が適合・不適合を判断可能，7 項目は有用な情報を取得できるものの最終判断にベンダーが保有する非公開の設計情報や文書等を要し，3 項目は内部実装，内部文書または評価対象範囲の確認が困難と分類した．さらに，適合性判断に利用可能な情報を取得できる 13 項目を対象に，★ 1 取得 IoT 機器 6 機種の実機調査および公開情報の確認によるケーススタディを実施した．ケーススタディでは，第三者が確認可能な範囲に明確な不適合や自己適合宣言との矛盾は確認されなかった．以上より，第三者が利用可能な情報のみで独立に適合性を判断できる範囲は限定的であり，制度運営機関のサーベイランスによる適切な検証の重要性が示唆された．

An Empirical Study on the Verifiability of JC-STAR ★1 Conformance Criteria Based on Information Available to Third Parties

Minato Watanabe[1,a)]　Soya Sanada[1]　Daichi Uezono[1]　Satoshi HARA[1,2]
Kosuke MURAKAMI[1,3]　Shota FUJII[1]　Takayuki Sasaki[1]　Katsunari Yoshioka[1]

Abstract: Cyberattacks targeting IoT devices are becoming increasingly serious, while users often find it difficult to assess product security before purchase. Against this background, JC-STAR was introduced to evaluate and communicate IoT product security based on common criteria. The JC-STAR ★ 1 label is granted on the basis of vendor self-declaration. Clarifying the extent to which such declarations can be independently corroborated using information available to third parties is expected to improve label transparency from a perspective distinct from internal conformity checks based on non-public evidence. This study examined the extent to which the requirements of all 16 ★ 1 criteria could be verified using information available to third parties. Six criteria were classified as independently decidable, seven as providing useful information while requiring non-public vendor information for a final decision, and three as difficult to verify because the necessary internal implementations, documents, or assessment scope could not be confirmed. We also conducted actual-device testing and reviewed publicly available information for six ★ 1-labeled IoT products, covering the 13 criteria for which useful information could be obtained. No clear nonconformity or contradiction with vendor declarations was identified within the observable scope. These results demonstrate that independent conformity decisions based solely on information available to third parties are limited and suggest the importance of appropriate verification through surveillance by the scheme operator.

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

近年，IoT 機器を標的としたサイバー攻撃が深刻化し，情報漏えいやボットネット化などの被害が報告されている．一方，ユーザが製品のセキュリティ対策を購入前に判断することはセキュリティ知識を前提として求めるなど難しい点がある．こうした背景から，IoT 製品のセキュリティを共通の基準で評価・可視化する制度として，JC-STAR が導入された [1]．このうち★ 1 では IoT 製品ベンダー以外の検査ではなく自己適合宣言に基づいてラベルが付与されるが，適合基準の曖昧さや検査員の判断基準の差などによって，本来★ 1 が求める基準と異なる検査結果となっている可能性がある．本研究では，JC-STAR ★ 1 を対象に，対象製品のベンダーおよび JC-STAR 制度運用者ではない第三者が適法に入手できる実機および情報から，適合性を確認できる程度を調査する．この検証はサーベイランス[*1]を代替するものではないが，自己適合宣言を外部から裏付けられる範囲を明らかにすることは，ラベルの適合性判断の透明性を高める効果が期待される．

そこで本研究では，次のリサーチクエスチョン（RQ）を設定する．

RQ: 第三者が利用可能な情報に基づいて，JC-STAR ★ 1 適合基準の各項目をどの程度検証できるか．

本研究では，まず，★ 1 適合基準 16 項目について，評価ガイドが適合性判断のために求める確認事項を，第三者が利用可能な情報から確認できるかを整理した．

その結果，16 項目のうち 6 項目は，評価ガイドが求める確認事項を実機から観測可能な挙動または公開文書のみですべて確認できるため，第三者が適合・不適合を判断可能であると考えられた．7 項目は判断に有用な情報を取得できるものの，最終的な判断にはベンダーが保有する非公開の設計情報や文書等を要した．残る 3 項目は，適合性判断に必要な内部実装，内部文書または評価対象範囲の確認が困難であった．次に，適合性の判断に有用な情報を取得できる 13 項目を対象に実機を用いたケーススタディを実施した．対象は★ 1 ラベルを取得した市販 IoT 機器 6 機種（6 ベンダー）であり，調査結果をベンダーが公開する自己適合宣言と比較した．ケーススタディでは，第三者が確認可能な範囲において，自己適合宣言と明確に矛盾する結果は確認されなかった．ただし，これは自己適合宣言の正確性を全面的に確認したことを意味しない．

[1] 横浜国立大学
Yokohama National University
[2] 富士ソフト株式会社
FUJI SOFT INCORPORATED
[3] 株式会社 KDDI 総合研究所
KDDI Research, Inc.
[a)] watanabe-minato-kf@ynu.jp

[*1] ラベル取得後に，IPA がベンダーへ証跡の提出を求めるなどして，適合状況を事後的に確認する仕組みを指す．

本研究の貢献は，JC-STAR ★ 1 適合基準 16 項目について，第三者が利用可能な情報に基づく検証可能性とその限界を体系的に整理した点，および 6 機種のケーススタディを通じて，第三者が確認できる事項と，それらの情報のみでは適合性判断に至らない事項を具体的に示した点にある．

2. 制度的背景と関連研究

2.1 JC-STAR

JC-STAR は，経済産業省の監督のもと IPA が運用する IoT 製品のセキュリティラベリング制度である [1]．セキュリティ水準に応じて★ 1〜4 の 4 段階の適合基準を定めており，★ 1・★ 2 はベンダーによる自己適合宣言，★ 3，★ 4 は第三者評価機関による評価に基づいてラベルが付与される．★ 1 適合基準は，アクセス制御，認証，ソフトウェア更新，インターフェースの無効化，情報の保護および情報提供等に関する 16 項目から構成される [2]．ベンダーは評価ガイド [3] に従って各項目への適合性を評価し，自己適合宣言を行う．評価ガイドでは，実機の機能・挙動を確認する評価に加えて，ベンダーが作成・保有する技術文書や内部文書を確認するドキュメント評価が規定されており，実装・挙動に関する要件であっても文書のみを用いて評価する項目が存在する．

適合評価に用いた証跡は原則としてベンダーが保管し，申請時に IPA による個別の適合性確認は行われない．一方，IPA はラベル取得後のサーベイランスにおいて，必要に応じてベンダーに証跡の提出を求め，自己適合宣言の内容を確認できる．したがって，非公開の証跡を利用できる制度上の確認と，実機や公開文書による外部からの検証では，利用できる情報の範囲が異なる．

また，制度運用開始前に実施された適合基準案の実証では，複数の製品についてベンダーによる自己評価と第三者による評価に差異が確認され，基準および評価手順の解釈の曖昧さがその要因として指摘されている [4]．これは，自己適合宣言における適合性判断が，基準および評価手順の解釈・適用によって異なり得ることを示唆している．

2.2 海外の IoT 製品向けセキュリティ制度と関連研究

IoT 製品のセキュリティに関する適合性評価・ラベリング制度は，日本の JC-STAR に限らず，欧米・アジア各国で整備されている．いずれも製品のセキュリティ要件を定め，適合性を一定の手続で確認する点で共通するが，第三者機関の関与の程度は制度によって異なる．

EU では，製造者自身による自己適合宣言を前提とした CE マーキングが，IoT 機器を含む無線機器の市場投入に用いられている．CE マーキングを付した市販 IoT 機器 8 機種を対象に実機調査を行った研究 [5] や，第三者認証を取得したモバイル IoT アプリ 11 件を対象に実装調査を行った研究 [6] は，いずれも申告された適合性と実際の実装と

© 2026 Information Processing Society of Japan

の乖離を実機調査によって明らかにし，第三者評価の必要性を指摘している．これらは実機調査を通じて申告と実装の関係を検討する点で本研究と共通する．

また，EU のサイバーレジリエンス法（CRA: Regulation (EU) 2024/2847）[7] は，デジタル製品全般を対象に，リスク区分に応じて自己評価と第三者評価を組み合わせる包括的な枠組みを採用している．CRA の要求事項を開発ライフサイクルへ組み込む方法を検討した研究 [8] は，セキュリティ要求を評価可能な要件へ具体化する点で本研究と接点を持つが，製造者側の視点から要件を演繹的に導出するものである．

アジア太平洋地域では，シンガポールの Cyber Security Agency（CSA）が Cybersecurity Labelling Scheme（CLS）[9] を運用している．CLS は ETSI EN 303 645 に基づく段階的なラベリング制度であり，JC-STAR の★1・★2 と★3・★4 のように，下位レベルは自己宣言，上位レベルは第三者評価という区分を持つ．

米国では，FCC が認定試験機関による製品試験を前提としたサイバーセキュリティラベリングプログラム，Cyber Trust Mark[10] を整備している．関連研究には，ラベルデザインや表示情報量が消費者の理解・購買行動に与える影響を検討したものがある [11], [12].

以上のように，海外の類似制度に関する先行研究は，制度設計の分析，実機調査による実装の問題発見，消費者側のラベル理解に大別され，個々の適合基準項目について第三者が利用可能な情報のみで検証可能性を整理したものは，筆者らが確認した範囲では見当たらない．本研究では，JC-STAR ★1 を対象として，この点を体系的に整理する．

3. 検証可能性の整理

3.1 検証者の能力

適合基準の検証可能性は，検証者の能力，利用可能な情報および製品固有の条件によって異なる．第三者による検証には，通常操作，公開情報および一般的な外部検査を用いる場合のほか，ファームウェア解析やリバースエンジニアリング等の高度な技術的調査を用いる場合も考えられる．本研究では，検証者像の一例として前者を想定し，その条件の下で各適合基準の検証可能性を整理する．

上記を踏まえ，本研究では，検証者がベンダーや制度運用者から特別な権限や非公開情報の提供を受けず，適法に入手した機器を通常の利用者として操作できることを前提とする．検証者は，Web UI の操作，製品 マニュアルや公式 Web サイト等の公開情報の確認，および制御されたネットワーク環境におけるポートスキャンや，一般に利用可能な脆弱性スキャンツールによる検査を実施できるものとする．一方，ファームウェアの抽出・解析，リバースエンジニアリング，バイナリ解析，ファジング，専用の解析機器による内部状態の確認，脆弱性の悪用を伴う侵入試験は，本研究で想定する検証者の能力および調査範囲に含めない．

3.2 検証可能性の分類基準と結果

本研究では，JC-STAR ★1 適合基準の 16 項目について，第三者が利用可能な情報に基づいて適合性をどの程度検証できるかを整理した．ここで，第三者が利用可能な情報とは，対象機器の実機調査によって取得可能な情報，および製品マニュアルや公式 Web サイト等でベンダーが公開する製品情報を指す．

本節の分類は，特定の機器群における実施結果を一般化したものではなく，3.1 節で定義した検証者の能力および調査範囲を固定したうえで，各適合基準が要求する確認事項と，その検証者が第三者として取得可能な情報との関係を分析した結果である．各適合基準について，評価ガイド [3] の評価内容を確認し，(1) 適合性判断に必要な事実は何か，(2) その事実を検証者が実機または公開情報から取得できるか，(3) 評価対象の範囲や網羅性を検証者が確認できるか，という観点から検討した．

検証可能性については，評価ガイド [3] が求める確認事項を，当該検証者が取得可能な情報のみで確認し，適合・不適合を判断できる性質の項目を「○」，判断に有用な情報を取得できるものの，対策の十分性や網羅性の確認にベンダーが保有する非公開の設計情報や文書等を要する項目を「△」，適合性判断に必要な内部実装，内部文書または評価対象範囲自体を確認することが困難な項目を「×」とした．整理結果を表 1 に示す．

なお，ファームウェアのバージョンを確認できない場合でも，各項目の検証可能性そのものは変わらず，機能・挙動を検証することは可能である．ただし，その結果を特定のファームウェアバージョンに帰属できないため，結果の再現性には制約が生じる．本研究のケーススタディでは，6 機種すべてでファームウェアバージョンを確認できたため，この問題は生じなかった．

3.3 適合基準ごとの検証可能性の分類理由

本節では，適合基準の各項目について，評価ガイドが求める確認事項と，3.1 節で定義した検証者の能力範囲で確認可能な事項および確認できない事項を整理し，表 1 に示した分類の理由を述べる．

3.3.1 S1.1-01 守るべき情報資産への適切なアクセス制御

評価ガイド上の確認事項． S1.1-01 では，IP 通信を介した守るべき情報資産へのアクセスについて，認証・アクセス制御により，許可された IoT 機器またはユーザのみがアクセスできることが求められる．認証・アクセス制御の方式としては，パスワード認証や IP アドレス制限，LAN 内限定通信等が示されている [2], [3].

分類理由（△）． Web UI や通信サービスの認証要求，LAN 内限定通信等，外部から到達可能な経路は，通常操作，LAN

© 2026 Information Processing Society of Japan

表 1: ★ 1 適合基準の第三者が利用可能な情報に基づく検証可能性

項目	適合基準の概要	第三者による検証可能性	第三者が利用可能な情報から確認できる事項	追加の設計情報等を要する事項
S1.1-01	守るべき情報資産への適切なアクセス制御	△	到達可能なインターフェースの認証・アクセス制御	内部サービスおよび非公開経路を含むアクセス経路の網羅性
S1.1-02	デフォルトパスワードの安全性	△	文字数，単純パターン，公開情報との明らかな対応関係	製品群全体における個体ごとの一意性，および非公開の生成方式を含む認証値生成方式の妥当性
S1.1-03	ユーザ認証値の変更可能性	○	変更手順の記載および実機での変更可否	—
S1.1-04	総当たり攻撃の困難性	△	試行制限・ロックアウト等の発現	制限機構の設定内容，対象となる認証経路の網羅性および制限機構の回避可能性
S1.1-05	脆弱性開示ポリシーの開示	○	公開されたポリシーにおける連絡先，報告受領後の手続き，解決までの状況更新手続きおよび掲載場所	—
S1.1-06	適切なファームウェアアップデートの実行可能性	○	更新可否，バージョン確認手段，再起動後の更新状態の維持	—
S1.1-07	ソフトウェアアップデートの分かりやすい手順の提供	○	ユーザ向けに公開されたアップデート手順の有無および内容	—
S1.1-08	ソフトウェアの完全性確認の仕組み	×	—	更新前の完全性確認機構の有無および妥当性
S1.1-09	アップデートの指針の文書化	×	—	アップデートの優先度を定める指針，脆弱性対応体制・プロセスおよび関係者間の連絡体制を記載した内部文書
S1.1-10	型番情報の提供	○	本体・GUI 等における型番表示	—
S1.1-11	守るべき情報資産のセキュアな保存	×	—	守るべき情報資産の定義，保存場所および保護機構等の内部実装
S1.1-12	ネットワーク上で転送される情報の盗聴対策	△	保護された通信環境でのみ利用する旨の公開記載	守るべき情報資産の定義，情報資産と通信との対応関係，保護対象通信の網羅性，ならびに暗号方式，鍵管理および保護方法の実装上の適切性
S1.1-13	利用上不要なインターフェースの無効化	△	外部から到達可能なポート・サービスおよび検出可能な脆弱性	各インターフェースが利用上不要であるかの判断，外部から検出されない脆弱性，および USB 等の物理インターフェースを含む無効化状態の網羅性
S1.1-14	電力供給や通信が断たれた後の設定の維持	○	電源断または通信断後における認証値および更新状態の維持	—
S1.1-15	ストレージ上の特定データの削除可能性	△	Web UI 等から確認可能なデータの削除	暗号鍵およびデジタル署名等のデータがストレージから実際に消去されたこと
S1.1-16	IoT 製品のサイバーセキュリティに関する情報提供	△	公開された安全な設定・使用手順，免責事項，サポート方針および安全な利用終了方法	アップデート情報の周知体制を示す技術文書

○：第三者が利用可能な情報のみで適合・不適合を判断可能，△：第三者が利用可能な情報から適合性判断に有用な情報を取得可能であるが，最終的な判断には追加の設計情報等が必要，×：適合性判断に必要な内部実装の確認または評価対象範囲の特定が困難，—：該当なし．

側・WAN 側のポートスキャンおよび通信サービスへの接続確認によって確認できる．一方，第三者が把握できない内部サービス・非公開経路の有無やアクセス制御の網羅性は，設計情報なしには確認できない．したがって，有用な情報は得られるものの，最終判断には非公開の設計情報等を要するため，△に分類した．

3.3.2 S1.1-02 デフォルトパスワードの安全性

評価ガイド上の確認事項． S1.1-02 では，デフォルトパスワードを使用する場合，機器ごとに一意で容易に推測可能でない 6 文字以上の値を用いるか，初回起動時に 8 文字以上のパスワード設定を強制することが求められる．容易に推測可能でないとは，単純なパターンや有名な単語，単純な規則に基づかず，MAC アドレス，SSID，型番等の公開情報にも基づかないことを指す [3].

分類理由（△）． パスワード変更の強制，文字数，単純なパターンや有名な単語との一致，SSID，型番，MAC アドレス等の公開情報との一致は，実機および公開情報から確認できる．一方，個体ごとの一意性や，非公開の生成方式は，複数個体の比較またはベンダーの設計情報等を要する．したがって，一部の性質は確認できるものの，生成方式や一意性を含む最終的な適合性の判断には追加情報を要するため，△に分類した．

3.3.3 S1.1-03 ユーザ認証値の変更可能性

評価ガイド上の確認事項． S1.1-03 では，ネットワークを介したユーザ認証に用いる認証値を，その種類によらず変更可能とし，変更手順をマニュアル等によってユーザが確

© 2026 Information Processing Society of Japan

認できることが求められる [3].

分類理由（○）. 認証値の変更機能は Web UI 等を実際に操作することで確認でき，変更手順の提供についてもマニュアル等の公開情報から確認できる．したがって，本項目は公開情報や検証者による通常の操作のみで適合・不適合を判断できる項目として○に分類した．

3.3.4 S1.1-04 総当たり攻撃の困難性

評価ガイド上の確認事項. S1.1-04 では，総当たり攻撃を困難にするため，連続した認証失敗に対して追加認証の禁止，一定期間の認証停止，認証応答の遅延等の制限を設けることが求められる．これらに代えて多要素認証を実装している場合も適合と判断される [2], [3].

分類理由（△）. 多要素認証の採用は，ログイン時の追加認証要求や設定画面からその有無を確認できる．認証試行の制限も，連続した認証試行によって外部から確認できる．一方，すべての認証経路が調査対象に含まれているか，制限機構の設定値や回避可能性は，外部から把握できない認証経路や設計情報に依存する．したがって，制限機構の発現は確認できるものの，その網羅性および十分性の最終判断には追加情報を要するため，△に分類した．

3.3.5 S1.1-05 脆弱性開示ポリシーの開示

評価ガイド上の確認事項. S1.1-05 では，脆弱性開示ポリシーを公開し，脆弱性の報告窓口，報告受領後の対応手順，および解決までの状況更新手順をユーザが確認できることが求められる [3].

分類理由（○）. 脆弱性開示ポリシーの公開，脆弱性の報告窓口，報告受領後の対応および解決に向けた状況更新の概要は，公式 Web サイト等の公開情報から確認できるため，本項目は○に分類した．

3.3.6 S1.1-06 適切なファームウェアアップデートの実行可能性

評価ガイド上の確認事項. S1.1-06 では，ファームウェアを更新できること，そのバージョンおよび最新版がインストールされていることを確認できること，ならびに更新後の状態が電源切断後も維持されることが求められる [3].

分類理由（○）. 更新可否，バージョンの確認方法，最新版の確認方法および更新後の状態維持は，Web UI，マニュアルおよび実機操作によって確認できる．したがって，本項目は公開情報や検証者による通常の操作のみで適合・不適合を判断できる項目として○に分類した．

3.3.7 S1.1-07 ソフトウェアアップデートの分かりやすい手順の提供

評価ガイド上の確認事項. S1.1-07 では，ソフトウェアアップデートについて，ユーザが確認・実施できる分かりやすい手順を提供することが求められる [3].

分類理由（○）. ソフトウェアアップデートを実行する手順については，マニュアルや公式 Web サイト等の公開情報から確認できるため，本項目は○に分類した．

3.3.8 S1.1-08 ソフトウェアの完全性確認の仕組み

評価ガイド上の確認事項. S1.1-08 では，ネットワーク経由のアップデート前に，機器または関連アプリケーションがハッシュ値またはデジタル署名を検証し，不正な場合はインストールを中止する仕組みが求められる．また，使用するアルゴリズムは電子政府推奨暗号リストに記載されたものであることが求められる [3].

分類理由（×）. アップデート前のハッシュ値またはデジタル署名の検証，検証失敗時のインストール中止，および使用する暗号アルゴリズムの適切性は，通常のアップデート操作だけでは確認できない．これらを確認するには，ベンダーの技術文書，ファームウェアや関連アプリケーションの解析等が必要となる．本研究で想定する検証者はこれらの調査を行わないため，×に分類した．

3.3.9 S1.1-09 アップデートの指針の文書化

評価ガイド上の確認事項. S1.1-09 では，セキュリティアップデートの優先度を決定する方針の文書化が求められる．具体的には，優先度の判断指針，脆弱性情報の収集から対策までの対応体制およびプロセス，ならびに関係者間の連絡体制が文書化されていることが求められる [3].

分類理由（×）. 本項目が評価する判断指標，脆弱性対応の内部プロセスおよび関係者間の連絡体制は，ベンダーの規程，方針，手順書等に記載される内部情報である．したがって，第三者が利用可能な情報のみでは確認が困難であり，×に分類した．

3.3.10 S1.1-10 型番情報の提供

評価ガイド上の確認事項. S1.1-10 では，IoT 製品の型番を機器本体，GUI，Web UI 等に記載し，ユーザが確認できるようにすることが求められる [3].

分類理由（○）. 型番は機器本体，GUI または Web UI 等の外部から確認可能な表示に記載される情報であり，実機または公開情報から確認できるため，○に分類した．

3.3.11 S1.1-11 守るべき情報資産のセキュアな保存

評価ガイド上の確認事項. S1.1-11 では，ストレージに保存される守るべき情報資産をセキュアに保存することが求められる．守るべき情報資産には，通信機能・セキュリティ機能に関する設定情報や，製品の利用において収集・保存される個人情報等が含まれ，保護方法としては暗号化やハッシュ化，外部インタフェースから直接読み書きできない領域への保存等が示されている [2], [3].

分類理由（×）. 本項目では，守るべき情報資産の種類，保存場所および保護方法を特定し，内部ストレージの保護状態を確認する必要がある．しかし，守るべき情報資産の範囲や内部ストレージ上の保護機構は，通常操作や外部からの観測のみでは網羅的に確認できない．そのような情報の確認にはベンダーの技術文書，設計情報またはファームウェア・ストレージの解析を要するため，×に分類した．

© 2026 Information Processing Society of Japan

3.3.12 S1.1-12 ネットワーク上で転送される情報の盗聴対策

評価ガイド上の確認事項．S1.1-12 では，ネットワーク経由で伝送される守るべき情報資産を，製品自体の保護対策または VPN・専用線等の保護された通信環境によって保護することが求められる．これらに代えて，保護された通信環境でのみ利用することをユーザ向けに明示する方法も認められている [2], [3].

分類理由（△）．保護された通信環境でのみ利用する旨が，公開文書や Web サイト等に明示されていれば，その記載に基づいて適合性を判断できる．一方，製品が扱う守るべき情報資産の定義，情報資産と通信との対応関係，保護対象となる通信の網羅性，ならびに暗号方式，鍵管理および保護対策の実装上の適切性の確認にはベンダーの技術文書，内部設計情報またはファームウェア等の解析が必要となる．したがって，適合性判断に有用な情報を取得できるものの，製品によっては追加の設計情報やファームウェア等の解析を要する項目として△に分類した．

3.3.13 S1.1-13 利用上不要なインターフェースの無効化

評価ガイド上の確認事項．S1.1-13 では，利用上不要で攻撃を受けるリスクのある TCP/UDP ポート，Bluetooth，USB のインタフェースを無効化するとともに，脆弱性検査を実施することが求められる．検査では，CVSS スコア 7.0 以上の脆弱性，および HTTP/HTTPS を利用する機能について CWE-78（OS Command Injection），CWE-89（SQL Injection），CWE-352（Cross-Site Request Forgery），CWE-22（Path Traversal）に関連する脆弱性が検出されないことが求められる [2], [3].

分類理由（△）．開放されている TCP・UDP ポート，Bluetooth や USB 等の外部インターフェースの一部，および脆弱性スキャンツールで検出可能な脆弱性は，実機調査で確認できる．一方，個々のインターフェースが製品の利用上不要であるか，外部から検出できないインターフェースや脆弱性がないか，および USB で利用可能なデバイスクラスを網羅できているか，脆弱性への対策が施されているかの確認には，ベンダーの技術文書や内部実装の解析等を要する．したがって，外部から確認できる事項はあるものの，対象範囲の網羅性や対策の適切性の判断には追加情報を要するため，△に分類した．

3.3.14 S1.1-14 電力供給や通信が断たれた後の設定の維持

評価ガイド上の確認事項．S1.1-14 では，電源または通信の切断後に機器が復帰・再接続しても工場出荷時の状態に戻らず，認証値および更新済みソフトウェアの状態を維持することが求められる [3].

分類理由（○）．認証値および更新済みソフトウェアの状態が，電源切断または通信切断後も維持されるかは，設定変更後に電源や通信を切断・再接続する実機操作によって確認できる．この確認に内部実装の解析や非公開の設計情報は必須ではないため，○に分類した．

3.3.15 S1.1-15 ストレージ上の特定データの削除可能性

評価ガイド上の確認事項．S1.1-15 では，製品利用中に取得した情報資産，ユーザ設定値，認証値，暗号鍵やデジタル署名等を削除でき，削除後も更新済みファームウェアのバージョンが維持されること，および削除方法がマニュアル等で提供されることが求められる．ただし，ユーザに公開されない製品固有の設定情報や，ベンダーが監視のために生成する技術データは削除対象外とされる [3].

分類理由（△）．Web UI 等からユーザ設定値や認証値を削除できること，および削除後のファームウェア状態の維持は，実機操作や公開情報から確認できる．一方，暗号鍵，デジタル署名およびその他のデータが内部ストレージから実際に消去されたか，また削除対象の情報資産を網羅しているかは，ストレージの内部状態や設計情報を確認なしには判断できない．したがって，削除機能の一部は確認できるものの，削除の完全性や対象範囲の最終判断には追加情報を要するため，△に分類した．

3.3.16 S1.1-16 IoT 製品のサイバーセキュリティに関する情報提供

評価ガイド上の確認事項．S1.1-16 では，ユーザがアクセス可能なマニュアルや Web サイト等において，安全な設定・使用手順，セキュリティアップデートの周知体制，アップデート未実施時の免責事項，サポート期間，および情報資産を残したまま廃棄・中古販売するリスクと安全な利用終了方法を提供することが求められる [2], [3].

分類理由（△）．安全な設定・使用方法，免責事項，サポート期間および安全な利用終了方法に関する情報は，製品ページ，マニュアル，サポートページ等の公開情報から確認できる．一方，アップデートの周知体制（媒体，方法，担当部署等）の整備状況は，関連技術文書が公開されていなければ確認できない．したがって，公開情報から適合性判断に有用な情報を取得できるものの，情報提供体制の存在を確認するには追加の文書またはベンダーが保有する情報を要するため，△に分類した．

3.4 検証可能性を分ける要因

表 1 および 3.3 節の分類理由から，検証可能性は，(1) 確認対象が外部から観測可能な機能・挙動であるか内部実装であるか，(2) 適合性判断に必要な情報や文書が第三者に公開されているか，(3) 機能や対策の存在だけでなく，その十分性や網羅性まで確認する必要があるか，(4) 評価対象の範囲を第三者が特定できるか，という要因に左右されると考えられる．

4. ケーススタディ

3 章で整理した検証可能性が実際の調査においても成り

© 2026 Information Processing Society of Japan

立つかを確認するため，○または△に分類した 13 項目を対象にケーススタディを実施した．

調査対象と方法．対象は，JC-STAR ★ 1 ラベルを取得した市販ルータ 6 機種（6 ベンダー）である．ルータを選定したのは，様々な機器をインターネットへ接続するゲートウェイとして広く利用されており，★ 1 適合基準が求める認証・アクセス制御，不要なインタフェースの無効化，ソフトウェア更新等の機能を備えるため，複数の項目を同一の手順で調査できるからである．内訳は家庭用 2 機種，産業用 4 機種である．

調査では，工場出荷状態に初期化した機器に対して，Web UI の操作確認，LAN 側・WAN 側からのポートスキャンおよび脆弱性検査を実施し，あわせてマニュアルや公式 Web サイト等の公開情報を確認した．評価環境および項目別の検証手順・結果は付録 A.2 に示す．

結果．○に分類した項目では，S1.1-06 を除き，6 機種すべてで適合性の判断に必要な事項を確認できた．S1.1-06 について，2 機種ではファームウェアの提供条件または調査時点のバージョンにより更新操作を実施できなかったが，更新手順は確認でき，更新機能の欠如を示す結果ではなかった．△に分類した項目については，3 章で想定したとおり，適合性判断に有用な情報は取得できたものの，対策の十分性や網羅性の確認には至らなかった．

また，調査結果をベンダーが公開する自己適合宣言と比較したところ，明確な不適合や自己適合宣言との矛盾は確認されなかった．ただし，一部の更新操作を実施できず，△に分類した項目については，第三者が利用可能な情報のみで適合性を確定できないため，自己適合宣言の正確性を全面的に確認したものではない．

5. 考察

5.1 ケーススタディから見た検証可能性を左右する要因

3 章で整理した検証可能性を左右する要因は，ケーススタディにおいても確認された．加えて，個別製品の状態や調査条件等，実際の検証過程に固有の制約も明らかとなった．

十分性・網羅性の確認の難しさ．外部から一部の挙動を観測できても，対策の十分性や網羅性まで判断できない場合があった．S1.1-01 では，把握したアクセス経路の認証・アクセス制御を確認できたが，第三者が存在を把握できない経路については試験できなかった．また，S1.1-15 では，Web UI 上で設定値等を削除できても，内部ストレージから実際に消去されたかは確認できなかった．

評価対象範囲の特定の難しさ．S1.1-13 では，検出したインターフェースが製品の利用上必要かを外部から判断できず，USB についても利用可能なデバイスクラスを網羅的に特定できなかった．このように，製品の設計や想定用途に関する情報なしには，観測したインタフェースを適合基準上の評価対象に対応付けることが困難な場合がある．

製品状態や調査条件による制約．S1.1-06 は，適合性判断に必要な機能・挙動を外部から確認できるため○に分類した．しかし，Router C ではファームウェアが既に最新版であり，実際の更新操作を実施できなかった．また，Router F では，更新ファームウェアの取得に製品利用者向けの所定の手続を要したため，研究目的の本調査では当該手続を行わず，更新操作を実施しなかった．このように，基準の性質上は第三者による検証が可能でも，個別製品の状態や調査条件によって，検証を完遂できない場合がある．

公開情報の所在を網羅的に把握する難しさ．S1.1-16 では，安全な設定・使用方法，免責事項，サポート期間および安全な利用終了方法に関する情報を，製品ページ，マニュアル，サポートページ等から確認した．しかし，これらの情報は単一のページに集約されていなかった．そのため，第三者が調査した情報源だけでは，ベンダーが公開する関連情報を網羅的に発見できたかを確認できない場合があった．このように，情報提供に関する項目では，情報の内容だけでなく，必要な情報がどの媒体に掲載されているかを第三者が把握できるかも，実際の検証可能性を左右する．

5.2 自己適合宣言方式への示唆

本研究で想定した検証者では，16 項目中 10 項目について，利用可能な情報のみでは適合性を最終判断できず，設計情報や内部文書等の追加情報を要した．したがって，外部から判断できない事項について，制度運営機関がサーベイランスを通じてベンダー保有の証跡を確認することは，適合性を検証する上で重要な役割を持つと考えられる．

また，本研究で用いた調査のうち，ポートスキャン，脆弱性検査，Web UI 上の操作，設定変更後の状態確認など，外部から観測可能な事項については，製品類型ごとに検証手順を定型化し，補助ツールとして実装できる可能性がある．さらに，使用したコマンドや設定，製品状態，実行日時および検査結果を共通の様式で記録することで，ベンダーによる自己評価の再現性を高め，第三者による結果の確認を容易にできると考えられる．一方，利用上不要なインタフェースの判断や，保護対象となる情報資産・通信範囲の網羅性の確認には，製品の用途や設計情報が必要であり，外部からの検査のみで適合性を判断することはできない．したがって，こうした手順の定型化や補助ツールは自己適合宣言における評価そのものを代替するものではなく，外部から確認可能な事項の評価と証跡の記録を支援する手段として位置付けられる．

5.3 本研究の限界

検証者の能力に関する限界．本研究の分類は，3.1 節で定義した検証者の能力および調査範囲を前提とする．ファームウェア解析等の高度な検証を行える検証者を想定すれば，S1.1-08，11，12 等の項目において内部実装の確認範囲が

© 2026 Information Processing Society of Japan

広がり，分類が変化する可能性がある．ただし，S1.1-11，12 のような項目では保護対象となる情報資産や通信範囲の特定に設計情報を要するため，検証手法の高度化のみでは適合性判断に至らない可能性がある．

ケーススタディの調査対象製品の限定．本研究では，ケーススタディの対象を★ 1 ラベルを取得したルータ 6 機種にとどめたため，他の製品類型を含むすべての IoT 製品に結果を一般化することはできない．

6. まとめ

本研究では，JC-STAR ★ 1 の適合基準 16 項目を対象として，第三者が利用可能な情報，すなわち実機調査によって取得可能な情報およびベンダーが公開する製品関連情報に基づく検証可能性を整理した．その結果，6 項目は第三者が利用可能な情報のみで適合・不適合を判断可能であり，7 項目は適合性判断に有用な情報を取得できるものの，最終的な判断にはベンダーが保有する非公開情報を要し，3 項目は適合性判断に必要な内部実装，内部文書または評価対象範囲の確認が困難であった．さらに，★ 1 ラベルを取得した市販 IoT 機器 6 機種を対象としたケーススタディでは，第三者が利用可能な情報に基づいて検証可能な範囲において，明確に不適合と判断できる機器は確認されなかった．以上より，JC-STAR ★ 1 の自己適合宣言について，第三者が利用可能な情報のみで独立に適合性を判断できる範囲は限定的であり，制度運営機関のサーベイランスによる適切な検証の重要性が示唆された．

謝辞　本研究の一部はＮＥＤＯ（国立研究開発法人新エネルギー・産業技術総合開発機構）の委託事業「経済安全保障重要技術育成プログラム／先進的サイバー防御機能・分析能力強化」（JPNP24003）によるものである．

参考文献

[1] 情報処理推進機構. セキュリティ要件適合評価及びラベリング制度（JC-STAR）. https://www.ipa.go.jp/security/jc-star/index.html. 2026 年 8 月 13 日参照.

[2] 情報処理推進機構. セキュリティ要件適合評価及びラベリング制度（JC-STAR）★ 1 レベル適合基準・評価手法. https://www.ipa.go.jp/security/jc-star/tekigou-kizyun-guide/label1/begoj90000004zgc-att/JC-STARlevel1_tekigoukizyun_hyouka.pdf, 2024. 2026 年 8 月 13 日参照.

[3] 情報処理推進機構. セキュリティ要件適合評価及びラベリング制度（JC-STAR）★ 1 評価ガイド. https://www.ipa.go.jp/security/jc-star/tekigou-kizyun-guide/label1/begoj90000004zgc-att/JC-STAR1_evaluation_guide_20250513.pdf, 2025. 2026 年 8 月 13 日参照.

[4] 経済産業省. IoT 製品に対する セキュリティ適合性評価制度 構築に向けた検討会 最終とりまとめ. https://www.meti.go.jp/shingikai/mono_info_service/sangyo_cyber/wg_cybersecurity/iot_security/pdf/20240315_1.pdf, 2024. 2026 年 7 月 8 日参照.

[5] Christoffer Lundh and Natalia Khetagourova. Evaluating security and data privacy in smarthome devices : A comparative experimental study of european and chinese products, 2022.

[6] Prianka Mandal, Amit Seal Ami, Victor Olaiya, Sayyed Hadi Razmjo, and Adwait Nadkarni. ”belt and suspenders” or ”just red tape”?: Investigating early artifacts and user perceptions of IoT app security certification. In *USENIX Security 24*, pp. 4927–4944, 2024.

[7] European Commission. Cyber resilience act. European Commission, Shaping Europe’s Digital Future. 2026 年 08 月 10 日参照.

[8] Miguel Ángel Ortega Velázquez, Iris Cuevas Martínez, and Antonio J. Jara. Integrating the cra into the iot lifecycle: Challenges, strategies, and best practices. *Information*, Vol. 16, No. 12, 2025.

[9] Cyber Security Agency of Singapore. Cybersecurity labelling scheme for iot: Overview of the scheme. Cyber Security Agency of Singapore. 2026 年 08 月 10 日参照.

[10] Federal Communications Commission. 47 cfr part 8 subpart b – cybersecurity labeling program for iot products. Electronic Code of Federal Regulations (eCFR). 2026 年 08 月 10 日参照.

[11] Peter Caven, Ambarish Gurjar, Zitao Zhang, Xinyao Ma, LJean Camp. Usability, Efficacy, and Acceptability of the U.S. Cyber Trust Mark. In *Association for Computing Machinery*, 2025.

[12] Claire C Chen, Dillon Shu, Hamsini Ravishankar, Xinran Li, Yuvraj Agarwal, and Lorrie Faith Cranor. Is a trustmark and qr code enough? the effect of iot security and privacy label information complexity on consumer comprehension and behavior. CHI ’24, 2024.

[13] James C Davis, Sophie Chen, Huiyun Peng, Paschal C Amusuo, and Kelechi G Kalu. A guide to stakeholder analysis for cybersecurity researchers, 2025.

[14] Greenbone AG. Greenbone community containers. https://greenbone.github.io/docs/latest/22.4/container/. 2026 年 7 月 8 日参照.

[15] 経済産業省. 機器のサイバーセキュリティ確保のためのセキュリティ検証の手引き. https://www.meti.go.jp/policy/netsecurity/wg3/kensyou_tebiki_r6kaitei.pdf, 2025. 2026 年 8 月 9 日参照.

[16] 情報処理推進機構. セキュリティ要件適合評価及びラベリング制度（JC-STAR）★ 1（レベル 1）評価補足ガイダンス. https://www.ipa.go.jp/security/jc-star/tekigou-kizyun-guide/label1/begoj90000004zgc-att/JC-STAR1_Supplemental_Evaluation_Guide_20250522.pdf, 2025. 2026 年 8 月 20 日参照.

© 2026 Information Processing Society of Japan

研究倫理

本研究では，市販 IoT 機器に対する実機調査を実施するにあたり，複数の倫理的課題を，Menlo Report の原則と Stakeholder-Based Ethics Analysis の枠組み [13] に基づき検討した．以下では，ステークホルダーごとの便益とリスク，講じた緩和策，および公表の判断を述べる．

ステークホルダー．本研究のステークホルダーは，(1) 調査対象とした 6 機種のベンダー，(2) 制度運用主体である IPA および経済産業省，(3)IoT 機器の調達者・利用者，(4) 調査対象外のベンダーを含む IoT エコシステム全体，(5) セキュリティ研究コミュニティ，および (6) 研究チームである．

便益とリスク．(1) 調査対象ベンダーにとって，本研究では明確に不適合と判断される機器は確認されておらず，調査結果は直接的に対象ベンダーの問題を示すものではない．一方，調査で得られた開放ポートや検出事象，適合性の判断が特定製品に結び付けられると，風評上の不利益を生じる可能性がある．とりわけ，JC-STAR の適合ラベル取得製品リストは事業者名を含めて公開されているため，本論文の匿名化した記述を公開情報と突合することで対象製品が再同定される可能性がある（**R1**）．

(2) 制度運用主体にとって，本研究は適合基準の第三者検証可能性とその限界を可視化し，サーベイランス等による補完が重要となる箇所を示すなど，制度改善の手がかりを提供する．一方，本研究は 6 機種を対象とした限定的なケーススタディであるため，結果が制度全体の実効性を示すものとして過度に一般化され，制度が一面的に評価される可能性がある（**R2**）．

(3) 調達者・利用者および (4)IoT エコシステム全体にとっては，★1 ラベルについて第三者が確認可能な範囲とその限界を理解できるという便益がある．一方，第三者が独立に検証できないことが適合基準を満たしていないことと誤解され，ラベルへの信頼を必要以上に低下させる可能性がある（**R3**）．

(5) セキュリティ研究コミュニティにとっては，IoT セキュリティラベリング制度の適合基準について，第三者が利用可能な情報から検証可能な範囲と限界を明らかにすることで，今後の適合性検証や評価手法の研究に利用可能な知見が得られる．一方，本研究成果には dual-use の側面があり，本研究で示す検証手法や機器の挙動に関する情報が攻撃対象の探索等に悪用され，ベンダーや利用者等に危害を生じさせる可能性がある（**R4**）．

(6) 研究チームにとっては，研究成果を公表する便益がある一方，市販機器の実機調査に伴い，意図しない機器の破壊や第三者インフラへの影響等のリスクを負う（**R5**）．

リスクの緩和策．上記のリスクを低減するため，以下の措置を講じた．

- **R1：対象機器ベンダーへの風評・再同定リスクへの対策．**製品名を「Router A」のように匿名化し，表 1 に示した検証可能性の整理は，特定機種の結果ではなく適合基準自体の性質として一般化して記述した．また，公開されている取得製品リストとの突合による再同定を避けるため，発売時期など識別につながる記述の粒度を粗くし，特徴的な事象は可能な限り複数機種に共通する事象として集約した．
- **R2：制度全体への過度な一般化リスク，R3：ラベルへの信頼低下リスクへの対策．**本研究は 6 機種を対象としたケーススタディであることを明示し，結果の適用範囲と限界を示した．また，第三者による検証可能性の限界と★1 適合性そのものを区別して記述し，本研究の結果を制度全体の実効性やラベルの信頼性に一般化しないようにした．
- **R4：悪用リスクへの対策．**悪用可能性を低減するため，用いた手法は Nmap や脆弱性検査ツール等の公開ツールに基づくものとし，開放ポートや検出事象は匿名化・集約した形で示した．また，実測したデフォルトパスワード等の認証値や攻撃に直接利用可能な情報は公開しないこととした．ケーススタディでは CVSS 7.0 以上，または対象とした CWE に該当する脆弱性は検出されなかったが，今後脆弱性が疑われる事象を確認した場合には，詳細を特定可能な形では公表せず，該当ベンダーへ個別に情報提供する方針である．
- **R5：実機調査による第三者・機器への影響リスクへの対策．**調査は購入・入手した機器自体への検査に限定し，第三者が管理するネットワークやサーバへのスキャン・攻撃は行わなかった．また，インターネット接続を要する調査でも対象機器がインターネットから到達不能となる構成のもとで実施し，機器の破壊や動作の不安定化につながりうる操作は行わなかった．

公表の判断．本研究は，★1 適合基準の第三者による検証可能性とその限界を明らかにし，制度改善や利用者の適切な理解に資する便益を有する．一方，上記のリスク（R1–R5）は，匿名化，結果の適用範囲の明示，悪用可能な情報の非公開，および調査環境の制限により低減した．以上より，公表による便益が残存するリスクを上回ると判断し，本研究成果を公表することとした．

© 2026 Information Processing Society of Japan

付　　録

A.1　Open Science

本研究の再現性と透明性のため，主張の評価に必要なデータ・成果物の所在と公開可否を述べる．本研究では，Nmap および Greenbone Community Edition 等の一般に入手可能なツールを使用した．各適合基準の検証手順は付録 A.2.3 に，評価環境，使用したツールのバージョン，Greenbone Community Edition の構成・スキャン設定および Nmap の実行コマンドは付録 A.2.2 に記載している．これらの情報により，同様の環境および条件において，本研究で実施した調査手順を追試できる．ただし，後述するように対象機器の製品名を匿名化しているため，本研究と同一の製品を用いた結果の完全な再現には制約がある．

公開可能なデータは，いずれも機器を匿名化した形で本論文に含めている．具体的には，適合基準 16 項目の検証可能性の整理（表 1），各基準の検証手順（付録 A.2.3），評価環境，使用コマンド，脆弱性検査ツールの構成・スキャン設定（付録 A.2.2），および Nmap ポートスキャン結果と脆弱性検査結果（表 A·1・表 A·2）である．後二者は機器を匿名化した集約結果であり，検出された脆弱性は低〜中程度のみで悪用可能なものを含まない．

一方，以下のデータは公開しない．匿名ラベル（Router A〜F）と実製品との対応関係は，特定ベンダー・製品への風評被害を避けるため公開せず，これにより匿名化した個別結果や開放ポート・脆弱性情報が識別可能な製品に結び付くことを防ぐ．実測したデフォルトパスワード等の認証値は，識別可能な製品と結び付いた場合に不正アクセスを容易にしうる機微情報であるため公開しない．また，対象機器のファームウェアはベンダーのライセンス上再配布できず，本研究の調査対象でもないため公開しない．なお，前述のとおりケーススタディでは悪用可能な脆弱性が検出されておらず，開示を留保している脆弱性データは存在しない．

A.2　ケーススタディの詳細

本付録では，実施したケーススタディについて，調査対象，評価環境，検証手順および項目別の結果を示す．

A.2.1　対象機器

本研究では，IoT 機器の代表例としてルータを調査対象とした．ルータは様々な機器をインターネットへ接続するゲートウェイとして利用されており，JC-STAR ★ 1 適合基準で求められる認証・アクセス制御，不要なインターフェースの無効化，ソフトウェア更新等の実装を実機調査によって確認しやすい．調査対象は，JC-STAR ★ 1 ラベルを取得した市販ルータ 6 機種（6 ベンダー）であり，その内訳は Router A および Router B が家庭用，Router C，Router D，Router E および Router F が産業用である．

A.2.2　評価環境

評価には，Apple MacBook Pro（機種 ID：Mac17,2，Apple M5，10 コア CPU，メモリ 32 GB2）を用いた．ホスト OS は macOS Tahoe 26.5.2 である．ネットワーク構成は評価内容に応じて WAN 側および LAN 側の 2 種類とした．

WAN 側の評価では，上位ネットワークを模擬するルータを介してスイッチに接続し，評価用 PC および評価対象機器の WAN 側インターフェースを同一ネットワーク上に接続した．LAN 側の評価では，評価用 PC と評価対象機器の LAN 側インターフェースを LAN ケーブルで直接接続した．

Web UI の評価は，各機器を工場出荷状態に初期化した後，初回起動時に要求される初期設定のみを実施した状態で行った．Web UI の確認には Google Chrome，ポートスキャンには Nmap 7.99，脆弱性検査には Greenbone Community Edition を用いた．

Greenbone Community Edition は，macOS 上の Docker Desktop4.78.0（ビルド 229452）に公式 Docker Compose 構成 [14] を用いて構築した．Docker Engine のバージョンは 29.5.3，Docker Compose のバージョンは v5.1.4 であり，Docker 環境は Linux/arm64，利用可能な資源は 10 コアおよび 7.75 GiB のメモリであった．主要コンポーネントは以下のとおりである．

- gvmd：バージョン 26.34.0．スキャンタスクの管理および実行を担当する．
- OpenVAS Scanner：バージョン 23.50.4．脆弱性スキャンエンジンである．
- NVT Feed：2026 年 7 月 27 日 07 時 57 分（UTC）更新．個々の脆弱性を検出するための検査ロジックのデータベースである．
- SCAP Feed：2026 年 7 月 28 日 05 時 05 分 20 秒（UTC）更新．CVE および CVSS 情報等の脆弱性識別データベースである．

脆弱性検査の設定には，経済産業省が公開する「機器のサイバーセキュリティ確保のためのセキュリティ検証の手引き」[15] に記載された GVM の設定例を採用した．設定内容は以下のとおりである．

- Port List：All TCP and Nmap top 100 UDP
- Scanner：OpenVAS Default
- Scan Config：Full and fast

TCP ポートのスキャンには以下のコマンドを用いた．

```
sudo nmap -r -p- -sS -Pn "IP アドレス"
```

UDP ポートについては，以下のコマンドを用いて上位 100 ポートを調査した．

© 2026 Information Processing Society of Japan

```
sudo nmap -r -sU -Pn --top-ports 100 "IP アドレス
"
```

A.2.3 各基準の検証手順と結果

A.2.3.1 ★ 1 適合基準 S1.1-01 守るべき情報資産への適切なアクセス制御

検証手順. 対象機器を初期状態に設定し，Web UI へのアクセス時に認証情報の入力が要求されるかを確認した．また，認証後にアクセス可能となる設定ページについて，未認証状態で URL を直接入力し，アクセスの可否を確認した．さらに，LAN 側および WAN 側から TCP ポートを探索し，Telnet や SSH 等の通信サービスが開放されている場合には，サービスへのアクセス時に認証が要求されるかを確認した．WAN 側からアクセス可能なサービスについては，外部からのアクセスが適切に制限されるかも確認した．ポートスキャンは初期状態および初回起動時の設定完了後に実施した．UDP ポートは，ユーザが管理画面へログインするための認証用途とは異なるため，本項目の調査対象外とした．

結果. 6 機種すべてにおいて，Web UI へのアクセス時にログイン ID とパスワードによる認証が要求された．また，認証後にアクセス可能な設定ページへ未認証状態で直接アクセスした結果，6 機種すべてで認証が要求された．

Telnet や SSH 等のサービスが開放されていた機器についても，アクセス時にパスワード認証が要求された．Router C では LAN 側で Telnet が開放され，Router F では LAN 側で SSH が開放されていた．また，Router C では WAN 側で Telnet および HTTP が開放されていた．HTTP へのアクセスではブラウザ上でアクセス拒否を示す表示が出て Web UI の内容は表示されなかった．Telnet では TCP 接続は確立したものの，ログインプロンプトや認証要求が表示される前に，相手機器から接続が切断された．

A.2.3.2 ★ 1 適合基準 S1.1-02 デフォルトパスワードの安全性

検証手順. S1.1-01 の調査で確認した認証機構について，初回起動時に 8 文字以上の新しいパスワード設定が強制されるかを確認した．デフォルトパスワードが設定されていて，新たなパスワード設定が強制されない場合には，それが単純なパターンや単語でないこと，および SSID，型番，MAC アドレス等の外部から取得可能な情報に基づくものでないことを確認した．なお，公開情報への依存性は，機器本体に記載された情報およびネットワーク上から取得可能な情報との比較によって調査した．

パスワードの機器ごとの一意性については，同一機種を複数台購入する必要があるため，本研究では確認しなかった．

結果. Router A，Router B では，初回起動時にパスワードの変更は求められず，デフォルトパスワードは 6 文字以上で単純なパターンや単語ではなく，SSID や型番，MAC アドレスといった公開情報とも一致しなかった．Router C，Router D ではデフォルトパスワードは単純なパターンであったが，初回起動時に 8 文字以上でパスワードを設定することが強制された．Router E，Router F では，デフォルトパスワードは設定されておらず，初回起動時に 8 文字以上でパスワードを設定することが強制された．

A.2.3.3 ★ 1 適合基準 S1.1-03 ユーザ認証値の変更可能性

検証手順. 対象機器のマニュアルを確認しながら Web UI や開放されている通信サービスで使用される認証値の変更を試み，変更後の認証値を用いてログインし，変更が反映されていることを確認した．

結果. 6 機種すべてにおいて，S1.1-01 で確認した認証機構に用いられる認証値を Web UI から変更できることを確認した．

A.2.3.4 ★ 1 適合基準 S1.1-04 総当たり攻撃の困難性

検証手順. Web UI や開放されている通信サービスに対して，正しいユーザ名と誤ったパスワードを用いた認証失敗を連続して行い，認証試行の制限，認証の停止または認証応答の遅延が発生するかを確認した．認証試行は最大 100 回とし，多要素認証の有無も確認した．

結果. Router A では，Web UI において 10 回連続して認証に失敗すると，機器を再起動するまで再度の認証試行ができない制限が発生した．Router B では 5 回，Router D および Router F では 10 回，Router C では Telnet および Web UI において 3 回の連続失敗後に，一定時間の認証試行制限が発生した．Router D では SSH についても，3 回の連続失敗後に一定時間の制限が発生した．

Router E では，一定回数の連続失敗による制限は確認できなかったが，各認証試行に遅延が設けられていた．

また，6 機種すべてにおいて多要素認証の使用は確認されなかった．

A.2.3.5 ★ 1 適合基準 S1.1-05 脆弱性開示ポリシーの開示

検証手順. 各対象機器のベンダーが公開する公式 Web サイトおよび脆弱性開示ポリシーを確認し，(1) 脆弱性の報告窓口，(2) 報告受領後の調査・対応手順，(3) 脆弱性の解決までの状況更新・情報公開手順が記載されているかを調査した．また，これらの情報をユーザがアクセス可能な媒体から確認できるかを確認した．本調査では，実際に脆弱性を報告した場合の対応や，ポリシーに記載された手続の運用状況は評価していない．

結果. Router A では，脆弱性の報告先，報告受領後の影響調査，修正の実施，報告者への連絡，および対応情報の公開方法が記載されていた．また，対応状況に応じて関係機関と連携し，脆弱性情報を公開する手順も示されていた．

Router B では，脆弱性報告用のフォームおよび関係機関

© 2026 Information Processing Society of Japan

を通じた報告方法に加え，報告受領後の影響調査，修正・緩和策の検討，報告者への連絡，ならびにセキュリティ情報の公開方法が記載されていた．

Router C では，脆弱性報告用のフォーム，報告受領後の通知，調査，必要な対応，および対応結果の公開に関する手順が記載されていた．

Router D では，脆弱性報告用のフォーム，報告受領後の影響評価，必要な対策の実施，関係者との調整，および脆弱性情報の Web サイト上での公開に関する手順が記載されていた．

Router E では，脆弱性報告用のフォーム，開発部門による分析，ソフトウェア更新や緩和策の提供，製品更新情報やフォーラムを通じた対応情報の公開に関する手順が記載されていた．

Router F では，脆弱性報告用のフォーム，受領通知，調査，対応方針の決定，進捗または遅延の連絡，および対応完了の通知に関する手順が具体的に記載されていた．

A.2.3.6 ★ 1 適合基準 S1.1-06 適切なファームウェアアップデートの実行可能性

検証手順．マニュアル等を参照しながらファームウェアの更新を試行し，更新が完了するかを確認した．また，Web UI 等でファームウェアのバージョンおよび最新版の確認が可能かを調査した．更新後には機器の電源を切って再起動し，ファームウェアのバージョンが維持されるかを確認した．

結果．6 機種すべてで，Web UI 上からファームウェアのバージョンを確認できた．Router B，Router D および Router E では，公式サイトで最新版を確認した上で，Web UI からファームウェアを更新できた．Router C では，Web UI 上に更新手段があることが確認できたが，購入時のファームウェアが最新版であることを公式サイトで確認でき，実際の更新は実施できなかった．Router F では，ファームウェアの取得および最新版の確認に，ベンダーへの個別申請と，それによる認証情報の取得が必要であった．この手続きは製品の実利用者を対象とした顧客向け手続きと考えられる一方，本研究は実利用を目的としない第三者調査であるため，そういった手続きを行うことは避けた．そのため，Router F では実操作でのファームウェアアップデートや最新バージョンの確認を行うことはできなかったが，これは正規利用者が所定の手続を経て更新機能を利用できないことを示すものではない．また，更新を実施できた機器では，電源切断・再起動後も更新後のファームウェアバージョンが維持されることを確認した．

A.2.3.7 ★ 1 適合基準 S1.1-07 ソフトウェアアップデートの分かりやすい手順の提供

検証手順．S1.1-06 の調査で参照したマニュアル，公式 Web サイトおよび Web UI を対象として，ソフトウェアアップデートの手順が記載されているかを確認した．S1.1-06 においてアップデート操作を実施しているため，本項目では手順の再実施は行わなかった．

結果．Router A では，Web UI からファームウェアを更新する手順および更新後のバージョン確認方法がマニュアル等に記載されていた．Router B，Router D および Router E では，公式 Web サイトから最新版のファームウェアを確認・取得し，Web UI から更新する手順がマニュアル等に記載されていた．Router C では，Web UI 上の更新手段および更新手順が確認できた．Router F では，ファームウェアの更新方法および更新に必要な権限・認証情報に関する説明が製品関連資料に記載されていた．

以上より，6 機種すべてについて，ソフトウェアアップデートの手順を確認できるマニュアル，公式 Web サイトまたは製品関連資料が提供されていることを確認できた．

A.2.3.8 ★ 1 適合基準 S1.1-10 型番情報の提供

検証手順．機器本体や Web UI 等の公開された情報源を確認し，実際に型番が記載されているか調査した．

結果．6 機種すべてで，機器本体に型番が記載されていることを確認した．

A.2.3.9 ★ 1 適合基準 S1.1-12 ネットワーク上で転送される情報の盗聴対策

検証手順．マニュアル，公式 Web サイト等を確認し，VPN・専用線等の保護された通信環境でのみ利用する旨が示されているかを調査した．本調査では，この記載の有無のみを確認し，暗号方式，通信内容および内部実装等については評価しなかった．

結果．6 機種すべてにおいて，VPN・専用線等の保護された通信環境でのみ利用する旨の明示は確認できなかった．

A.2.3.10 ★ 1 適合基準 S1.1-13 利用上不要なインターフェースの無効化

検証手順．TCP・UDP ポートの探索には Nmap を用い，脆弱性検査には Greenbone Community Edition の公式 Docker Compose 構成を用いた．同構成には，スキャン管理を担う gvmd および OpenVAS Scanner 等が含まれる [14]．この構成は，IPA の補足ガイダンスが脆弱性検査ツールの例として OpenVAS および GVM を挙げていることを踏まえて選定した [16]．

TCP ポートの調査は S1.1-01 の評価と同時に行い，UDP ポートは上位 100 ポートを対象とした．ポートスキャンは初期状態および初回設定完了後に，LAN 側および WAN 側から実施した．

脆弱性検査は対象機器の IP アドレスに対して LAN 側および WAN 側から実施し，CVSS スコア 7.0 以上の脆弱性が検出されないかを確認した．また，検出された範囲において，HTTP/HTTPS を利用する機能について CWE-78（OS Command Injection），CWE-89（SQL Injection），CWE-352（Cross-Site Request Forgery）および CWE-22（Path Traversal）に関連する脆弱性の有無を確認した．

© 2026 Information Processing Society of Japan

ただし，本研究では Web UI 上の全 URL パスを網羅的に探索する検査や，脆弱性の悪用を伴う侵入試験は実施していない．全 URL パスの網羅には，製品ごとの認証状態，画面遷移，セッション管理および動的な通信を反映した個別設定が必要となるため，共通かつ再現可能な手順には含めなかった．したがって，本研究の検査結果は，設定した検査条件および到達可能な範囲における検出結果を示すものであり，HTTP/HTTPS の全 URL パスに脆弱性が存在しないことを示すものではない．

結果．Nmap により外部から到達可能なポートの存在を確認したが，個々のインターフェースが製品の利用上不要であるかは，製品の用途や設計情報に依存するため判断できなかった．詳細なスキャン結果は表 A·1 に示す．

脆弱性検査では，設定した検査条件および到達可能な範囲において，6 機種すべてでファームウェアリリース時点で公表されていた CVSS スコア 7.0 以上の脆弱性は検出されなかった．また，検査対象とした HTTP/HTTPS 機能について，CWE-78，CWE-89，CWE-352 および CWE-22 に関連する脆弱性も検出されなかった．ただし，全 URL パスを網羅した検査ではないため，対象脆弱性が存在しないことを全面的に確認したものではない．詳細な検査結果は表 A·2 に示す．

A.2.3.11 ★ 1 適合基準 S1.1-14 電力供給や通信が断たれた後の設定の維持

検証手順．Web UI へのログインに用いる認証値を変更し，ファームウェアを更新した後，電源または通信を切断した．その後，電源や通信を再接続し，認証値およびファームウェアの状態が維持されているかを Web UI 等で確認した．電源は機器が稼働している状態で電源プラグを抜くことで切断した．通信については，WAN 側および LAN 側のケーブル，無線接続，その他利用可能な通信機構を切断した．

結果．6 機種すべてにおいて，電源または通信の切断後も機器は工場出荷時の状態に戻らず，変更した認証値およびファームウェアのバージョンが維持されていることを確認した．

A.2.3.12 ★ 1 適合基準 S1.1-15 ストレージ上の特定データの削除可能性

検証手順．マニュアル等を確認しながら，ユーザ設定値およびユーザが設定した認証値等の削除を試行した．暗号鍵やデジタル署名の削除状況，および内部ストレージ上で実際にデータが消去されたかについては，環境上の制約から直接確認できなかったため，Web UI 等から確認可能な範囲で評価した．データ削除後には，ファームウェアのバージョンが維持されているかを確認した．

結果．6 機種すべてにおいて，機器上のユーザ設定値およびユーザが設定した認証値を Web UI 上で削除できることを確認した．一方，内部ストレージ上のデータが実際に消去されたかについては，第三者が利用可能な情報のみでは確認できなかった．また，データ削除後もファームウェアのバージョンが維持されることを確認した．

A.2.3.13 ★ 1 適合基準 S1.1-16 IoT 製品のサイバーセキュリティに関する情報提供

検証手順．各機器の製品マニュアル，公式 Web サイト，ファームウェア更新情報，サポート情報および IPA のラベル取得製品情報を調査し，評価ガイドに示された 5 項目に対応する情報の有無と内容を確認した．アップデートの周知体制については，公開された通知媒体や通知方法に加え，評価ガイドが求める担当部署等を記載した技術文書を，第三者が利用可能な情報から確認できるかを調査した．

結果．安全な設定・使用手順については，6 機種すべてで，初期設定，認証値の変更，ファームウェア更新およびセキュリティ設定等に関する情報を確認した．また，サポート期間についても，6 機種すべてのラベル取得製品情報において，ラベル有効期間中にサポートが提供されることを確認した．アップデートの周知については，6 機種すべてで，公式 Web サイト，サポートサイトまたは登録ユーザへの通知等，更新情報をユーザへ提供する手段を確認した．一方，通知媒体，周知方法および担当部署等を定めた内部の技術文書は，いずれの機器についても第三者が利用可能な情報から確認できなかった．免責事項については，Router B，Router D および Router E で，アップデートを実施しない場合に想定される不正アクセス，情報漏えい，機能不全等と，それらに関する免責事項を確認した．Router A，Router C および Router F では，アップデートに関する注意事項または一般的な免責事項は確認できたものの，アップデート未実施時に想定される事故・障害とその免責の両方は確認できなかった．安全な利用終了方法については，Router B，Router C および Router E で，情報資産を残したまま廃棄または譲渡することによる情報漏えい・不正アクセス等のリスクと，初期化やデータ消去による安全な利用終了方法を確認した．Router A，Router D および Router F では，初期化，ログ削除またはストレージ消去等の手順は確認できたが，情報資産を残したまま廃棄・中古販売するリスクに関する説明は確認できなかった．

A.2.3.14 自己適合宣言との比較

以上の調査結果をベンダーが公開する自己適合宣言と比較した結果，第三者が利用可能な情報に基づいて確認可能な範囲では，自己適合宣言と明確に矛盾する結果は確認されなかった．ただし，△に分類された項目については，第三者が利用可能な情報のみでは適合性を確定できないため，自己適合宣言の正確性を全面的に確認したものではない．

© 2026 Information Processing Society of Japan

表 A·1: Nmap スキャン結果

ルータ	設定	IF	TCP(Open)	UDP(Open)	UDP(Open—Filtered)
Router A	初期	WAN	なし	なし	全 100 ポート
Router A	初期	LAN	53,80,443	53,137,1900	なし
Router B	初期	WAN	なし	なし	全 100 ポート
Router B	初期	LAN	53,80	53,5353	67,1900,49193
Router C	初期	WAN	80	53,123	67,500,4500
Router C	初期	LAN	23,80	123	53,67,500,4500
Router C	設定後	WAN	23,80	123	53,67,500,4500
Router C	設定後	LAN	23,80	123	53,67,500,4500
Router D	初期	LAN	22,443	53,67	なし
Router D	設定後	LAN	22,443	53,67	なし
Router E	初期	LAN	53,443	53,67	なし
Router E	設定後	LAN	53,443	53,67	158,427,49194
Router F	初期	WAN	53,443,16385	53	68
Router F	初期	LAN	53,443,16385	53	68
Router F	設定後	WAN	53,443,16385	53	68
Router F	設定後	LAN	53,443,16385	53	68

表 A·2: Greenbone Community Edition による脆弱性診断結果

ルータ	**IF**	**CVSS $\geq$ 7.0**	**検出された脆弱性**
Router A	LAN	なし	TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router A	WAN	なし	なし
Router B	LAN	なし	TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router B	WAN	なし	なし
Router C	LAN	なし	Telnet Unencrypted Cleartext Login (CVSS 4.8, Medium), Cleartext Transmission of Sensitive Information via HTTP (CVSS 4.8, Medium), TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router C	WAN	なし	なし
Router D	LAN	なし	SSL/TLS: Certificate Expired (CVSS 5.0, Medium), TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router E	LAN	なし	TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router F	LAN	なし	TCP Timestamps Information Disclosure (CVSS 2.6, Low)
Router F	WAN	なし	TCP Timestamps Information Disclosure (CVSS 2.6, Low)

© 2026 Information Processing Society of Japan